

Why was this denied: Access Analyzer, the simulator and CloudTrail

Closing Domain 4 with the diagnostic tools – and the three Access Analyzer products most courses treat as one.

Three different questions. Did it happen,
could it happen, and can it ever happen?

Three analyzers, three products

ANALYZER	ANSWERS	COST
External access	Can anyone outside my zone of trust reach this resource?	No additional charge
Internal access	Which principals inside my organisation can reach this resource?	Per resource, per Region
Unused access	Which roles, keys, passwords and permissions are nobody using?	Per role or user

ON THE EXAM

Most material describes only the external one. Internal access analyzers are newer and answer the question auditors actually ask.

External access findings

- ◆ Analyses **resource-based policies** for anything granting access outside your **zone of trust** – an account or an organisation.
- ◆ An external principal can be another account, a root user, a user or role, a federated user, **a service, or an anonymous user**.
- ◆ It uses **automated reasoning**, so a finding is a proof rather than an observation.
- ◆ **Access previews** test a policy change **before** you deploy it.
- ◆ It reasons about **resource policies**. An over-broad identity policy is a different analyzer.

ON THE EXAM

A finding is not automatically a problem. Intended cross-account access appears too.

Internal access findings

- ◆ Which principals inside your organisation or account can access a resource you nominate.
- ◆ It reasons across identity policies, resource policies and the organisation ceilings together.
- ◆ **PRINCIPAL_LIMIT_EXCEEDED** fires when more than 3,000 principals can reach a resource.
- ◆ How you answer 'who can read the customer database' without reading forty policies.
- ◆ Charged per resource per Region – point it at crown jewels, not everything.

ON THE EXAM

External: who outside can get in. Internal: who inside already can.

Unused access findings, and the one you may already have

- ◆ Finds **unused roles, access keys, console passwords, and unused service and action-level permissions.**
- ◆ The practical route to least privilege – remove what nobody exercised.
- ◆ **Enabling Security Hub for an organisation creates a service-linked analyzer in every member account.**
- ◆ That one has a **fixed 90-day lookback** you cannot configure.
- ◆ So it is easy to pay for two analyzers doing overlapping work.

ON THE EXAM

Check whether you already have it. Security Hub may have switched it on for you.

Policy checks and policy generation

- ◆ **Basic policy validation** – 100+ checks against grammar and best practice. No extra charge.
- ◆ **CheckNoNewAccess** compares a new policy against the old and fails if broader. Made for a pipeline.
- ◆ **CheckAccessNotGranted** asserts actions are never permitted. **CheckNoPublicAccess** asserts a policy is not public.
- ◆ **Policy generation** builds a policy from **CloudTrail activity** – least privilege from what happened.
- ◆ Custom checks are charged per API call.

ON THE EXAM

CheckNoNewAccess in a pull request is the most useful of these.

The policy simulator, and what it will not tell you

- ◆ Evaluates a **hypothetical** request against your policies and reports allowed or denied, naming the statement that decided it.
- ◆ Useful before you make a change, and useful for answering 'would this role be able to'.
- ◆ **It simulates. It does not tell you what happened.** For a denial that already occurred, CloudTrail is the source of truth.
- ◆ It tests **one request**. Access Analyzer reasons about **all possible** requests, which is a different kind of claim.
- ◆ Check what a given simulation covers before you rely on it – the ceilings from module 19 are not all evaluated the same way.

ON THE EXAM

Simulator: could this work. CloudTrail: did it. Access Analyzer: could it ever, for anyone.

Reading an AccessDenied in CloudTrail

- ◆ The event has **errorCode AccessDenied** and an **errorMessage**. Read the message.
- ◆ It often names the policy type: '**with an explicit deny in a service control policy**'.
- ◆ **userIdentity** gives the principal; **sessionContext** the role and session.
- ◆ An implicit deny gives a vaguer message – nothing denied it, and nothing allowed it.
- ◆ Module 1: a denied call is still a logged call. Absence means it was never made.

ON THE EXAM

If the message names a policy type, most of the investigation is already done.

The order to diagnose in

01

Read it

The CloudTrail errorMessage may name the policy type outright.

02

Deny?

Scan for an explicit deny - SCP, RCP, resource policy, identity policy.

03

Ceilings

Boundary and session policy. Silence in either is a denial.

04

Grants

Same account, either grant. Cross-account, both are needed.

05

Simulate

Reproduce it in the simulator once you have a hypothesis.

ON THE EXAM

Simulating first is the common mistake. Read the error, then form a hypothesis, then simulate to confirm it.

A bank must give its regulator documented assurance that no principal outside its AWS Organization can access three S3 buckets holding card data, across 200 accounts.

The team offers eighteen months of CloudTrail logs showing no access from outside the organisation. The regulator says this does not answer the question that was asked.

What should the bank provide?

- ☐ A IAM Access Analyzer external access findings with the organisation as the zone of trust
- ☐ B Policy simulator results for each of the three buckets against a sample external principal
- ☐ C An AWS Config rule confirming the buckets have Block Public Access enabled
- ☐ D Extended CloudTrail retention plus Athena queries proving no external access occurred

◆ PAUSE AND DECIDE

What should the bank provide?

- A

 External access findings with the org as the zone of trust
Correct. Automated reasoning proves a statement about every possible request, which is a stronger claim than any amount of observed history.
- B

 Simulator results against a sample principal
Tests the principals you thought to test. The regulator asked about every external principal, and a sample proves nothing about the ones you did not sample.
- C

 Config rule for Block Public Access
Necessary and not sufficient. Block Public Access stops anonymous access; a bucket policy naming a specific external account is not public and is still external.
- D

 More CloudTrail and Athena
More of the evidence the regulator has already rejected. Absence of observed access proves nobody used a path, not that no path exists.

THE SIGNAL

The same distinction as module 15's Network Access Analyzer scenario, one layer up. Observation versus proof.

A healthcare provider's board asks a simple question about its patient records DynamoDB table: exactly which people and workloads inside the company can read it today?

The security team has confirmed there is no external access. Answering the internal question means tracing identity policies, resource policies, permissions boundaries and SCPs across 40 accounts, which they estimate at three weeks of work.

What should the team use?

- ☐ A External access analyzer with the account as the zone of trust
- ☐ B Unused access analyzer, then subtract the unused principals
- ☐ C The policy simulator, run once per principal across the 40 accounts
- ☐ D An internal access analyzer with the table as a selected critical resource

◆ PAUSE AND DECIDE

What should the team use?

- A** External access analyzer, account zone of trust
Narrowing the zone of trust to the account would report other accounts in the organisation as external. It still says nothing about principals inside the account.
- B** Unused access, then subtract
Unused access tells you who has not used a permission recently. Not using access is not the same as not having it - which is the question.
- C** Simulator once per principal
Would eventually work and is the three weeks of manual work restated. It also only covers principals you remembered to enumerate.
- D** Internal access analyzer on the table
Correct. It reasons across identity policies, resource policies and organisation ceilings together to report exactly which internal principals can reach a nominated resource.

THE SIGNAL

'Which principals inside can reach this' is the internal access analyzer's one-line description. The question is the product name.

An engineer with a role carrying AdministratorAccess receives AccessDenied calling ec2:RunInstances in eu-west-1. CloudTrail records the event with errorCode AccessDenied and an errorMessage stating the request was denied with an explicit deny in a service control policy.

The engineer opens the policy simulator, tests the role against ec2:RunInstances, and it reports Allowed. They conclude CloudTrail is wrong.

What should the engineer do?

- ☐ A Re-run the simulation with the resource ARN specified, which will reveal the denial
- ☐ B Examine the SCPs applying to the account; the error message has already named the policy type
- ☐ C Raise a support case, since the simulator and CloudTrail disagree
- ☐ D Check the role's permissions boundary, which is what produces this message

◆ PAUSE AND DECIDE

What should the engineer do?

A Re-run with the resource ARN

A reasonable simulator habit and it does not address this. The message names an SCP, and a more precise simulation of the identity policy will not surface it.

C Raise a support case

They do not disagree. CloudTrail reports what happened; the simulator reports a hypothetical over the policies it evaluated. Different questions, different answers.

B Examine the SCPs; the message named the policy type

Correct. The error message has already done the hard part. An explicit deny in an SCP beats AdministratorAccess, exactly as module 19 said.

D Check the permissions boundary

A boundary produces an implicit deny by being silent, not an explicit deny in an SCP. The message would read differently.

THE SIGNAL

The engineer had the answer in the first line and went looking for a second opinion. Read the error message first.

A retailer with 200 accounts and around 4,000 IAM roles wants to remove permissions nobody uses. Security Hub was enabled for the organisation eight months ago and is used daily.

A platform engineer proposes creating an unused access analyzer in every account with a 180-day lookback, and has costed it as a new line item.

What should the engineer check first?

- ☐ A Whether the accounts have AWS Config enabled, which unused access analysis requires
- ☐ B Whether IAM Access Analyzer supports 180-day lookbacks in all Regions
- ☐ C Whether Security Hub has already created service-linked analyzers, whose lookback is fixed at 90 days
- ☐ D Whether the roles are tagged, since unused access analysis reports by tag

◆ PAUSE AND DECIDE

What should the engineer check first?

A Whether AWS Config is enabled

Config is a real prerequisite elsewhere – Security Hub CSPM controls and Firewall Manager both need it. Unused access analysis reads IAM last-accessed data, not Config.

C Whether Security Hub already created service-linked analyzers

Correct. Enabling Security Hub for an organisation creates one in every member account automatically, with a fixed 90-day lookback – so some of this may already exist.

B Whether 180-day lookbacks are supported

Configurable lookback is a normal feature of an analyzer you create. The question is whether they need to create one at all.

D Whether the roles are tagged

Tags help you organise findings and are not a prerequisite. Unused access analysis works on principals regardless of tagging.

THE SIGNAL

'Security Hub has been enabled for eight months' is not scene-setting. It tells you infrastructure already exists.

Six things to carry forward

- ◆ **Did it happen is CloudTrail. Could it happen is the simulator. Can it ever happen is Access Analyzer.**
- ◆ **External asks who outside can get in. Internal asks who inside already can.** Auditors often mean the second.
- ◆ **Automated reasoning proves; observation only records.** That is why logs do not satisfy a regulator asking about possibility.
- ◆ **Read the errorMessage first.** It often names the policy type and skips most of the investigation.
- ◆ **Security Hub creates service-linked analyzers automatically,** with a fixed 90-day lookback.
- ◆ **CheckNoNewAccess in a pipeline** turns 'is this policy change safe' into a build step.

ON THE EXAM

That closes Domain 4. Next: Domain 5, data protection – starting with KMS.